

Report Tecnico: Scansione Vulnerabilità e Fingerprinting

Target: Metasploitable 2 (IP 192.168.1.190)

1. Obiettivo

L'obiettivo di questo esercizio è identificare i vettori di attacco disponibili sull'host target attraverso l'enumerazione delle porte aperte, il rilevamento delle versioni dei servizi e l'identificazione del sistema operativo (OS Fingerprinting).

2. Metodologia

È stato utilizzato lo strumento Nmap per eseguire una scansione attiva.

Il comando lanciato combina:

- **SYN Scan (-sS)**: Per una scansione rapida e furtiva dello stack TCP.
- **Version Detection (-sV)**: Per interrogare le porte e ottenere le versioni specifiche dei demoni.
- **OS Fingerprinting (-O)**: Per analizzare i pacchetti TCP/IP e determinare il kernel del sistema operativo.

Comando Eseguito

```
sudo nmap -sS -sV -O 192.168.1.190
```

3. Risultati della Scansione (Output)

Address

- 192.168.1.190 (IPv4)

Ports

The 977 ports scanned but not shown below are in state: **filtered**

- 977 ports replied with: **no-response**

Port	State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp open	ftp	syn-ack	vsftpd	2.3.4	
22	tcp open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1	protocol 2.0
23	tcp open	telnet	syn-ack	Linux telnetd		
25	tcp open	smtp	syn-ack	Postfix smtpd		
53	tcp open	domain	syn-ack	ISC BIND	9.4.2	
80	tcp open	http	syn-ack	Apache httpd	2.2.8	(Ubuntu) DAV/2
111	tcp open	rpcbind	syn-ack		2	RPC #100000
139	tcp open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
445	tcp open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
512	tcp open	exec	syn-ack			
513	tcp open	login	syn-ack			
514	tcp open	tcpwrapped	syn-ack			
1099	tcp open	java-rmi	syn-ack	GNU Classpath grmiregistry		
1524	tcp open	bindshell	syn-ack	Metasploitable root shell		
2049	tcp open	nfs	syn-ack		2-4	RPC #100003
2121	tcp open	ftp	syn-ack	ProFTPD	1.3.1	
3306	tcp open	tcpwrapped	syn-ack			
5432	tcp open	postgresql	syn-ack	PostgreSQL DB	8.3.0 - 8.3.7	
5900	tcp open	vnc	syn-ack	VNC		protocol 3.3
6000	tcp open	X11	syn-ack			access denied
6667	tcp open	irc	syn-ack	UnrealIRCd		
8009	tcp open	ajp13	syn-ack	Apache Jserv		Protocol v1.3
8180	tcp open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	

Remote Operating System Detection

- Used port: **21/tcp (open)**
- OS match: **Oracle Virtualbox Slirp NAT bridge (98%)**
- OS match: **AT&T BGW210 voice gateway (95%)**
- OS match: **QEMU user mode network gateway (94%)**

Si può vedere dal report di nmap che ci sono una grande quantità di porte aperte di vitale importanza che pongo un enorme rischio di sicurezza come:

Porta 22 tcp servizio ssh versione 4.7p1 debian ubuntu protocollo 2.0.

Porta tcp 23 fornisce il servizio telnet.

Porta 80 servizio http apache versione 2.2.8 ubuntu DAV/2

139 e 445 netbios samba smbd versione 3.X - 4.X

1524 metasploitable root shell

La differenza che ho notato tra lo scan tcp connect (-sT) e stealth scan, syn (-sS) È che nello scan tcp, wireshark mostra una risposta ACK che indica che il protocollo di handshake a 3 vie è stato portato a termine e quindi è stata effettivamente stabilita una connessione prima di essere immediatamente chiusa.

Questo richiede più tempo ed è più invasivo e facilmente rilevabile.

In uno scan -sS i movimenti dei pacchetti rilevati in wireshark non mostreranno mai un ACK in risposta.